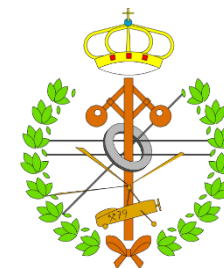




universidad
de león



Máster de investigación en ciberseguridad

Diseño y Programación Seguras

Entrega 2

Tarea 2: Cuestionario de asesoramiento de seguridad

Assignment 2: Security Assessment Questionnaire

Autor: Rubén Canillas Mañanes

Índice general

Análisis de Ciberamenazas 2.0	1
Índice general	3
Índice de tablas	4
1. Resumen de los cuestionarios	1
2. Evaluación global y elección	5
3. Aplicación de VSAQ a una aplicación hipotética	7
3.1. Descripción de la aplicación	7
3.2. Preparación del contexto (inspiración CUNY/CMU)	8
3.3. Selección de módulos VSAQ	9
3.4. Complimentación del cuestionario en la aplicación	9
3.5. Análisis de resultados y plan de acción	10
Bibliografía	12

Índice de tablas

Tabla 1: Comparativa de cuestionarios.

4

1. Resumen de los cuestionarios

Id (Compañía, Fecha, Actualizaciones)	Objetivo del Cuestionario	Usuarios Objetivo	Descripción	Positivo	Negativo	Otros
Application Security Assessment – CMU (Carnegie Mellon Univ., ISO)	Decidir el tipo y profundidad de la evaluación de seguridad requerida por la oficina de seguridad.	Responsables de proyectos internos y proveedores externos.	Formulario de "intake" en Word. Detalla propósito, datos, arquitectura, autenticación y backups.	Excelente para entender el contexto general antes de controles finos; integración formal.	Muy ligado a roles y terminología interna de CMU; requiere adaptación externa.	Referencia útil para diseñar formularios de admisión propios en entornos académicos.
VSAQ – Vendor Security Assessment (Google, 2016 - Código Abierto)	Estandarizar y agilizar evaluaciones de proveedores mediante	Equipos de seguridad, compras TI y desarrolladores.	App web con plantillas JSON. Soporta lógica de ramificación y	Flexible, modular y técnico. Evita preguntas irrelevantes	Requiere infraestructura web o uso de demo; no es un simple	Altamente personalizable para políticas internas o evaluaciones

	cuestionarios interactivos.		guardado de sesiones.	gracias a su lógica dinámica.	documento para firmar.	de apps propias.
Application Security – HIMSS (Sector Sanitario, Versión Actual)	Evaluar seguridad en software sanitario alineado con HIPAA/HITECH (protección de ePHI).	Proveedores de software sanitario y organización es de salud.	Autoevaluación sobre control de acceso, cifrado, backups y cumplimiento normativo.	Muy específico para sanidad; traduce requisitos legales (HIPAA) a preguntas técnicas.	Menos aplicable fuera de salud; contenido basado en esquemas que pueden ser antiguos.	Útil como checklist de "controles fuertes" incluso si no se manejan datos ePHI.
SANS – Blueprint for Risk Assessment (SANS/GIAC, White Paper)	Proponer un modelo sistemático para análisis de riesgos, impacto y amenazas.	Auditores, consultores de seguridad y equipos de riesgo.	White paper con metodología y plantillas para valorar sensibilidad, backups y amenazas.	Aporta metodología estructurada y ayuda a priorizar acciones basadas en riesgo.	No es un cuestionario listo para usar; requiere recopilación previa de datos.	Ideal para interpretar y priorizar los resultados obtenidos de otros cuestionarios.

Vendor Security – Purdue (Secure Purdue, Excel v8.7)	Determinar si una nueva adquisición requiere una revisión formal de seguridad.	Departament os internos de compras y proveedores de servicios TI.	Hoja de cálculo Excel por pestañas (Cloud, On-prem, datos, certificados, soporte).	Muy práctico y sencillo de entender para perfiles no técnicos; integrado en compras.	Enfoque procedimental universitario; no profundiza en detalles finos del SDLC.	Sirve como plantilla base para flujos de adquisición de software y servicios.
Information Security – CUNY/CCNY (City Univ. NY, v1.2r, 2019)	Identificar riesgos y requisitos en proyectos con información no pública.	Responsabl es de proyectos internos y administrado res de sistemas.	Formulario sobre tipo de datos, perfiles de acceso, cifrado, logging y alojamiento.	Bueno para clasificar información y "pintar" el contexto; preguntas genéricas útiles.	No profundiza en desarrollo seguro; muy orientado a procesos internos de CUNY.	Ideal como etapa previa de clasificación antes de un cuestionario técnico.
PCI DSS Self-Assessment (SAQ) (PCI SSC, v3.x/v4.0)	Autoevaluación frente a requisitos de PCI DSS para el tratamiento de datos de tarjetas.	Comercios, proveedores de servicios de pago (PSP) y	Serie de cuestionarios (A-D) con preguntas de sí/no/NA según el modelo de negocio.	Estándar de oro reconocido globalmente; extremadamente exhaustivo en controles.	Muy específico para pagos; pesado, burocrático y fuera de	Indispensable si hay transacciones ; referencia puntual de buenas

		e-commerce			contexto aporta poco valor.	prácticas en otros casos.
--	--	------------	--	--	-----------------------------	---------------------------

Tabla 1: Comparativa de cuestionarios.

2. Evaluación global y elección

El propósito de esta comparación consta de dos partes claramente diferenciadas. En primer lugar, entender para qué tipo de sistemas y organizaciones resulta más adecuado cada cuestionario, de manera que se identifiquen las limitaciones derivadas del sector (sanidad, pagos) o del entorno (universidad, proveedor concreto). En segundo lugar, seleccionar una combinación razonable de instrumentos para evaluar una aplicación web moderna genérica, en la cual pueden existir datos internos sensibles, pero que no se encuentra sujeta de forma directa a normativas específicas como PCI DSS o HIPAA.

A partir de la tabla anterior se observa que tres de los cuestionarios tienen un enfoque eminentemente sectorial o regulatorio (HIMSS para sanidad, PCI SAQ para pagos y, en menor medida, el enfoque SANS que está más ligado a la disciplina de análisis de riesgos que a un dominio concreto). Otros tres están muy vinculados a procesos internos de instituciones universitarias (CMU, Purdue, CUNY), actuando como formularios de intake y contextualización para sus revisiones internas. Sólo VSAQ se plantea desde el origen como una herramienta generalista, aunque, en la práctica, surgió para escalar las revisiones de seguridad de proveedores en una empresa de gran tamaño como Google.

En consecuencia, si se busca un cuestionario principal, capaz de cubrir tanto aspectos técnicos de la aplicación web como elementos de infraestructura y proceso de desarrollo, sin quedar atrapado en un único sector o en la estructura de una institución concreta, VSAQ se presenta como la opción más equilibrada. Su modularidad permite reparar en las partes que tienen sentido (webapp, infraestructura, programa de seguridad) y obviar otras en caso de que no apliquen. Además, al ser interactivo, se ajusta bien a la realidad de sistemas donde ciertas prácticas ya se encuentran implantadas, reduciendo el esfuerzo cuando algunas familias de controles no son relevantes o ya están resueltas con claridad.

Por todo ello, el cuestionario que prefiero para una aplicación genérica y moderna es VSAQ, utilizando CMU/Purdue/CUNY como inspiración para el formulario previo de contexto, y reservando HIMSS y PCI SAQ sólo para el caso en que se incorporen componentes sujetos a esos marcos regulatorios.

3. Aplicación de VSAQ a una aplicación hipotética

3.1. Descripción de la aplicación

El propósito de la aplicación hipotética, a la que denominaremos OpsBoard Portal, consta de dos partes, por un lado centralizar la visualización y gestión de eventos operativos de una organización que presta servicios críticos (por ejemplo, una empresa de infraestructuras o de transporte) y, por otro, facilitar la toma de decisiones por parte de los operadores y supervisores que trabajan en un centro de control. Para lograrlo se plantea una arquitectura de tipo cliente-servidor basada en un frontend web en React, que consume una API REST implementada sobre un backend de microservicios en Python, desplegándose ambos componentes en contenedores dentro de un clúster de Kubernetes alojado en un proveedor de nube pública.

La aplicación recibe eventos desde distintos sistemas fuente (sensores, plataformas de monitorización, aplicaciones internas), los almacena en una base de datos relacional y en un almacén de logs, y posteriormente los presenta en forma de paneles, tablas y mapas en tiempo casi real, permitiendo filtrar por tipo de evento, zona, prioridad u otros parámetros definidos por el usuario. Desde el punto de vista de datos, OpsBoard Portal maneja información interna sensible relacionada con el estado de los servicios, posibles incidencias, datos de usuarios internos (identidad, rol, horario de trabajo) y, en algunos casos, referencias a activos físicos. No gestiona información de tarjeta ni datos clínicos, por lo que no entra directamente en el ámbito de PCI DSS ni de HIPAA, situándose en una categoría similar a los sistemas con datos “internos” o “restringidos” descritos en el cuestionario de CUNY.

Por último, el acceso a la aplicación se realiza mediante autenticación corporativa basada en SSO (OIDC), de forma que OpsBoard Portal delega la verificación de identidad en el proveedor de identidad y se centra únicamente en gestionar sesiones y roles propios (operador, supervisor, administrador). Esta decisión simplifica parte del modelo de seguridad, pero introduce a

su vez dependencias con el ecosistema de identidad de la organización, aspecto que deberá reflejarse en el cuestionario VSAQ y en la valoración global.

3.2. Preparación del contexto (inspiración CUNY/CMU)

Antes de aplicar VSAQ se completa un pequeño bloque de contexto inspirado en los formularios de CMU y CUNY, cuya finalidad es describir de forma concisa qué es OpsBoard Portal, qué datos trata y cómo se expone. En este bloque se identifican:

Categorías de datos: públicos (p.ej. información agregada que ya se publica en informes), internos (eventos y métricas operativas), restringidos (incidencias sensibles, anotaciones internas, datos personales de empleados).

Perfiles de usuario: operadores de primera línea, supervisores, administradores técnicos y, eventualmente, auditores internos.

Canales de acceso: red corporativa, VPN, acceso remoto seguro; se documenta si existe cualquier exposición directa a Internet.

Ubicación y alojamiento: clúster de Kubernetes en nube pública, base de datos gestionada, servicios de logging y monitorización externos.

Este contexto servirá como referencia al interpretar las respuestas de VSAQ y al priorizar riesgos a posteriori.

3.3. Selección de módulos VSAQ

Del conjunto disponible de cuestionarios VSAQ se seleccionan los siguientes:

Web Application Security Questionnaire: centrado en autenticación, gestión de sesiones, control de acceso, vulnerabilidades típicas de aplicaciones web, protección de datos en tránsito y en reposo, logging a nivel de aplicación.

Infrastructure Security Questionnaire: orientado a sistemas subyacentes (servidores, cloud, contenedores, redes), parches, hardening, controles de acceso a la infraestructura y segmentación.

Security & Privacy Program (en la medida necesaria): para evaluar cómo se integran las prácticas de seguridad y privacidad en el ciclo de vida de desarrollo, la gestión de vulnerabilidades y la respuesta a incidentes.

No se seleccionan módulos específicos de entornos que no apliquen (por ejemplo, cuestionarios orientados a centros de datos físicos si toda la infraestructura es cloud gestionada).

3.4. Cumplimentación del cuestionario en la aplicación

El proceso de cumplimentación del cuestionario se plantea como una sesión conjunta entre el responsable técnico de OpsBoard Portal y un miembro del equipo de seguridad. En la parte de aplicación web se documenta el uso de SSO con OIDC, indicando que la aplicación no almacena contraseñas, pero sí tokens de sesión y cookies protegidas, describiendo cómo se gestionan la expiración y revocación de sesiones, y si existe o no autenticación multifactor para los perfiles críticos. También

se describe el uso de HTTPS con TLS moderno en todas las conexiones externas al portal, el uso de cabeceras de seguridad (HSTS, X-Frame-Options, etc.) y los controles implementados para mitigar ataques tipo XSS, CSRF e inyección.

En el cuestionario de infraestructura se reflejan las características del clúster de Kubernetes (tipo de servicio, aislamiento de entornos, política de actualización de nodos, uso de imágenes oficiales y registries privados), así como la existencia de NetworkPolicies, mecanismos de control de acceso a la consola de administración y procedimientos de hardening de los nodos. Se describe asimismo cómo se protege la base de datos gestionada (cifrado en reposo, credenciales rotadas, acceso restringido por red) y los servicios de logging (si se utilizan servicios gestionados, cómo se controla el acceso a logs y cuánto tiempo se mantiene la información).

Por último, en el bloque de programa de seguridad se indica si el equipo aplica revisiones de código sistemáticas, si existe un pipeline de CI/CD que incluya análisis estático, escaneo de dependencias y pruebas automatizadas, y cómo se gestionan las vulnerabilidades detectadas (registro, priorización y tiempos de remediación). También se recoge si hay un plan de respuesta ante incidentes documentado, ejercicios de simulación y comunicación con otros equipos de la organización.

3.5. Análisis de resultados y plan de acción

Con el cuestionario completado, se analizan los resultados tomando como referencia los criterios de riesgo sugeridos por SANS, es decir, evaluando el impacto y la probabilidad de los fallos detectados sobre la confidencialidad, integridad y disponibilidad de OpsBoard Portal. Por ejemplo, si se detecta que aún no se ha implantado MFA para cuentas con permisos de administración de la plataforma, se clasifica esta debilidad como un riesgo de impacto alto y probabilidad media, dadas las capacidades que tendría un atacante con acceso a dichas cuentas. Si se comprueba que existen copias de seguridad, pero no se realizan pruebas periódicas de restauración, se identifica un riesgo de disponibilidad, con impacto alto y probabilidad baja-media.

A partir de esta valoración se elabora un plan de acción priorizado que incluye medidas como habilitar autenticación multifactor para roles críticos, integrar herramientas de análisis estático y escaneo de dependencias en la cadena de CI/CD, ajustar la configuración de Kubernetes para aplicar perfiles de seguridad más restrictivos y reforzar la política de logging y auditoría para asegurar la trazabilidad de las operaciones. De este modo, la aplicación práctica de VSAQ no se queda en un mero ejercicio documental, sino que se convierte en la base de un proceso de mejora continua que puede repetirse periódicamente para comprobar el grado de avance y revalorar los riesgos en función de la evolución del sistema y de las amenazas.

Bibliografía

1. Google. (2016). *VSAQ: Vendor Security Assessment Questionnaire* [Repositorio GitHub]. GitHub. <https://github.com/google/vsaq>[github]
2. Google. (2016, 6 marzo). *Scalable vendor security reviews* [Entrada de blog]. Google Open Source Blog. <https://opensource.googleblog.com/2016/03/scalable-vendor-security-reviews.html>[opensource.googleblog]
3. Healthcare Information and Management Systems Society. (2007). *Application Security Questionnaire v2.3* [Cuestionario]. HIMSS. <https://www.himss.org/application-security-questionnaire>[himss]
4. Healthcare Information and Management Systems Society. (2007). *Application Security Questionnaire for Healthcare* [Documento]. HIMSS. <https://studylib.net/doc/8316650/application-security-questionnaire>[studylib]
5. Purdue University. (2020, 31 mayo). *New IT solutions and services review* [Sitio web]. Secure Purdue. <https://www.purdue.edu/securepurdue/services/solution-services-review.php>[purdue]
6. Purdue University. (2020). *Vendor Security Questionnaire 8.7* [Hoja de cálculo]. Secure Purdue. <https://www.purdue.edu/securepurdue/document/VendorSecurityQuestionnaire%208.7.xlsx>[purdue]
7. Bronx Community College, City University of New York. (2019). *Information Security Review Questionnaire Form v1.2r* [Formulario]. http://www.bcc.cuny.edu/wp-content/uploads/2019/08/information_security_review_questionnaire_form

[_v1.2r.pdf\[bcc.cuny\]](#)

8. Payment Card Industry Security Standards Council. (s. f.). *PCI DSS Self-Assessment Questionnaire (SAQ) types* [Página de referencia]. University of California, San Francisco - Controller's Office.
<https://controller.ucsf.edu/reference/accounts-receivable-banking-services/pci-dss-self-assessment-questionnaire-saq-types>[controller.ucsf]
9. McLean, T. (2001). *Application Security, Information Assurance's Neglected Stepchild - A Blueprint for Risk Assessment* [White paper]. SANS Institute / GIAC.
<https://www.giac.org/paper/gsec/986/application-security-information-assurances-neglected-stepchild-blueprint-risk-assessmen/101990>[giac]